

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – CASE STUDY

COURSE CODE: ITA14

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)

Assessment Tool Weightage: 35%

QUESTIONS: 5

Total Marks:100

-
1. A mid-sized e-commerce company hosts its web application on an Apache server running on a Linux environment. Recently, customers reported unauthorized transactions and abnormal account activities. Upon investigation, the IT team discovered suspicious HTTP requests in server logs, including attempts to access hidden directories and injection of malicious scripts into input fields. Additionally, the server is running an outdated version with known vulnerabilities, and no Web Application Firewall (WAF) is implemented. As a cybersecurity analyst, you are tasked with conducting a comprehensive security assessment using Kali Linux. Analyze the possible attack vectors exploited by the attacker, including web server vulnerabilities, input validation issues, and outdated software components. Explain in detail how you would perform reconnaissance, vulnerability scanning, and exploitation using appropriate Kali Linux tools. Further, propose a layered defense strategy that includes server hardening, secure coding practices, and network-level protections to prevent such incidents in the future.
 2. A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this scenario. Describe a step-by-step methodology using Kali Linux tools such as Burp Suite and SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies, including input validation, output encoding, secure session handling, and implementation of security controls.
 3. A corporate office provides wireless internet access to employees using WPA2-PSK authentication. Recently, several employees reported unusual login prompts and slow network performance. A security investigation revealed the presence of a rogue access point (Evil Twin) mimicking the official network SSID. Attackers used this setup to capture login credentials and perform man-in-the-middle (MITM) attacks. You are tasked with analyzing the breach and strengthening wireless security. Explain how the attacker successfully executed the Evil Twin attack and intercepted sensitive data. Describe how Kali Linux tools such as Aircrack-ng and Wireshark can be used to detect and analyze such attacks. Evaluate the weaknesses in the existing wireless security configuration. Propose robust countermeasures, including secure authentication mechanisms, network monitoring, and user awareness strategies.

4. An organization's internal network hosts a web-based employee management system accessible over Wi-Fi. The wireless network uses weak passwords, and the web application lacks proper authentication and session management. An attacker gains access to the Wi-Fi network, performs reconnaissance, and exploits vulnerabilities in the web application to escalate privileges and access confidential employee data. You are assigned to perform a full penetration testing assessment. Analyze the attack chain starting from wireless network compromise to web application exploitation. Describe each phase of the attack, including reconnaissance, scanning, exploitation, and privilege escalation. Demonstrate how Kali Linux tools can be used in each phase. Propose a comprehensive security framework that addresses both wireless and web application vulnerabilities, ensuring defense-in-depth.
5. A university campus experiences frequent Wi-Fi disruptions during peak hours. Investigation reveals repeated deauthentication attacks targeting access points, causing legitimate users to disconnect. The attacker uses automated tools to continuously send deauth packets, leading to denial of service. You are tasked with identifying the cause and implementing solutions. Explain how deauthentication attacks are carried out in wireless networks and how attackers exploit protocol weaknesses. Describe how Kali Linux tools can be used to simulate and analyze such attacks in a controlled environment. Evaluate the impact on network availability and user productivity. Recommend effective mitigation strategies, including network configuration changes, intrusion detection systems, and secure wireless protocols.

Code of Conduct:

I ch jaswanth(192372199) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Case	25	Thorough understanding; clearly identifies all key issues	Good understanding with most issues identified	Basic understanding; some issues missed	Poor understanding; problem not identified correctly
Application of Concepts	25	Effectively applies relevant concepts to analyze the case deeply	Applies appropriate concepts with minor gaps	Limited application of concepts	Fails to apply relevant concepts
Analysis	20	In-depth analysis with strong reasoning and insights	Good analysis with logical reasoning	Basic analysis with limited depth	Weak or no analysis; lacks reasoning
Solution Design	20	Innovative, feasible solutions with strong justification	Logical solutions with adequate justification	Basic solutions with weak justification	Incorrect or no solution provided

Clarity	10	Clear, wellstructured, and easy to understand	Organized and understandable presentation	Limited clarity and structure	Poor clarity difficult to understand
---------	----	---	---	-------------------------------	--------------------------------------

ANSWER 1:

Possible Attack Vectors

- Directory/hidden-path enumeration: attacker probed for unlinked admin panels, backup files, and config directories (e.g. /admin, /backup, /.git) that were never removed from production.
- Input validation failure: unsanitised form fields (search box, login, checkout) allowed injection of malicious scripts (Stored/Reflected XSS) that hijacked customer sessions to perform unauthorized transactions.
- Outdated Apache version: known CVEs (e.g. path traversal, mod_cgi/mod_php remote code execution bugs) in the unpatched server let the attacker gain deeper access once a foothold was found.
- Absence of a WAF: malicious payloads (script tags, traversal sequences, SQL meta-characters) reached the application layer with zero filtering, so no request was ever blocked or logged as an anomaly.

Reconnaissance (Information Gathering)

- whois and nslookup/dig to gather domain registration and DNS record details of the target.
- Nmap (nmap -sV -p- <target>) to fingerprint open ports, the Apache version, and the underlying OS.
- WhatWeb / Wappalyzer-cli to identify the exact web stack (Apache version, PHP version, CMS/plugins in use).
- Gobuster / dirb / dirbuster to brute-force hidden directories and files (the same class of endpoints the attacker abused).
- theHarvester for OSINT on employee emails and exposed subdomains that widen the attack surface.

Vulnerability Scanning

- Nikto (nikto -h <target>) to scan the Apache server for outdated modules, dangerous files, and misconfigurations.
- OpenVAS / Nessus (via Kali) to run an authenticated/unauthenticated CVE scan against the identified Apache version.
- searchsploit <apache-version> to cross-reference the fingerprinted version against the Exploit-DB database for known public exploits.
- OWASP ZAP for automated crawling and passive scanning of input fields for reflected/stored XSS indicators.

Exploitation (Controlled/Authorized Testing)

- Metasploit Framework: search and load a module matching the CVE found by searchsploit to validate remote code execution or file disclosure risk in a lab/authorized environment.

- Burp Suite Repeater/Intruder to manually craft and replay XSS payloads into the vulnerable input fields and confirm script execution/session-token theft.
- curl / Burp Suite to manually request the discovered hidden directories and confirm sensitive file exposure (config files, backups, credentials).

Layered Defense Strategy

- Server hardening: patch Apache to the latest stable version, disable unused modules (mod_status, mod_info), remove default/backup files, run the service under a least-privilege user, and disable directory listing.
- Secure coding practices: validate and sanitise all inputs on the server side (allow-list validation), use output encoding/escaping for anything rendered back to the browser, and adopt parameterised queries for any database access.
- Network-level protections: deploy a Web Application Firewall (e.g. ModSecurity with OWASP CRS) in front of Apache, place the server behind a reverse proxy/CDN, enforce HTTPS/TLS everywhere, and add rate-limiting plus an IDS/IPS (e.g. Snort) to flag repeated probing of hidden paths.
- Continuous monitoring: centralised log analysis (ELK/SIEM) for anomalous 404/403 bursts and periodic automated vulnerability re-scans (Nikto/OpenVAS) as part of a patch-management cycle.

Question 2:

ANSWER

How the Vulnerabilities Can Be Exploited

- SQL Injection: since inputs (login form, account-search fields) are concatenated directly into SQL queries, an attacker submits crafted strings (e.g. a single quote or UNION-based payloads) to alter query logic, bypass authentication, or dump entire tables.
- Verbose error messages leak table/column names and DBMS type, turning a blind guess into a guided, error-based injection.
- Cross-Site Scripting: unsanitised input reflected or stored (e.g. in a transaction note or profile field) executes attacker JavaScript in another user's browser, allowing session-cookie theft or forged transaction requests.

Step-by-Step Methodology

- Mapping: use Burp Suite Proxy/Spider (with browser traffic routed through it) to crawl the application and catalogue every input point — login, search, transfer forms.
- Manual probing: in Burp Repeater, inject a single quote (') or classic payload into each parameter and observe whether the server returns a SQL error or behaves differently — confirms injectability.
- Automated validation with SQLmap: run `sqlmap -u "<url>" --data="<params>" --batch --dbs` to enumerate databases, then `--tables` and `--dump` on a chosen table to prove data extraction is possible (in an authorized test environment only).
- XSS testing: use Burp Suite Intruder to fuzz each field with a payload list (script tags, event handlers) and check the HTTP response/rendered page for unescaped reflection; confirm stored XSS by revisiting the page as a different session.

- Session/logic checks: inspect cookies in Burp for missing HttpOnly/Secure flags and test whether the session token changes after login (session fixation check).
- Documentation: log every proof-of-concept request/response pair as evidence for the audit report, mapped to the specific parameter and vulnerability class.

Impact on the CIA Triad

- Confidentiality: SQL injection allows bulk extraction of customer PII and account data; XSS enables theft of session tokens, giving the attacker read access to another user's account.
- Integrity: injection can be used to UPDATE/INSERT records (e.g. altering balances), and XSS can silently submit forged transactions on behalf of a logged-in victim.
- Availability: destructive SQL statements (DROP/heavy nested queries) or automated injection tooling can degrade database performance or take the service offline, denying legitimate customers access.

Mitigation Strategies

- Input validation: enforce strict, allow-list server-side validation (type, length, format) on every field, rejecting anything that doesn't match the expected pattern.
- Parameterised queries / prepared statements (or an ORM) everywhere, eliminating string-concatenated SQL entirely.
- Output encoding: context-aware encoding (HTML, JS, URL) of all user-supplied data before it is rendered, plus a strict Content-Security-Policy header to blunt any missed XSS.
- Secure session handling: HttpOnly + Secure + SameSite cookies, session regeneration on login/privilege change, short idle timeouts, and re-authentication for sensitive transactions.
- Security controls: generic error messages (no stack traces/DB details) shown to users while detailed errors are logged server-side; a WAF tuned for SQLi/XSS signatures; regular static/dynamic code scanning and periodic penetration testing.

Question 3

ANSWER

How the Evil Twin Attack Was Executed

- The attacker set up a rogue access point broadcasting the same SSID as the legitimate corporate network, often with a stronger signal near where employees sit.
- Using deauthentication frames (802.11 management frames are unauthenticated), the attacker forced connected clients to disconnect from the genuine AP.
- Employee devices, configured to auto-reconnect to a known SSID, associated with the rogue AP instead, believing it to be the corporate network.
- The rogue AP presented a fake captive-portal login page, capturing usernames/passwords as employees re-entered credentials, and routed all subsequent traffic through the attacker's machine — enabling a classic man-in-the-middle position.

Detection & Analysis with Kali Linux Tools

- airmon-ng start wlan0 puts the wireless adapter into monitor mode for packet capture.

- airodump-ng wlan0mon scans the airwaves and lists every AP/BSSID broadcasting each SSID — a duplicate SSID with two different BSSIDs (or mismatched vendor OUI) is a strong Evil Twin indicator.
- Wireshark, run on captured traffic, is used to filter on wlan.fc.type_subtype == 0x0c (deauthentication frames) to reveal abnormal spikes of deauth packets that preceded the credential-capture window.
- Comparing signal strength (RSSI) and channel of the two BSSIDs in airodump-ng helps pinpoint the rogue device's physical location.

Weaknesses in the Existing Configuration

- WPA2-PSK uses a single shared passphrase with no mechanism for a client to verify the AP's identity, so any device broadcasting the right SSID/PSK can impersonate the real network.
- 802.11 management frames (including deauthentication) are not protected/authenticated in this setup (no 802.11w/PMF), letting the attacker forcibly disconnect clients at will.
- No wireless intrusion detection/prevention system (WIDS/WIPS) was in place to flag rogue APs or deauth floods automatically.

Recommended Countermeasures

- Migrate to WPA3-Enterprise or 802.1X/EAP-TLS with certificate-based mutual authentication, so devices cryptographically verify the AP before connecting.
- Enable 802.11w (Management Frame Protection) to prevent unauthenticated deauthentication/disassociation attacks.
- Deploy a WIDS/WIPS to continuously scan for rogue APs and duplicate-SSID anomalies and alert the security team in real time.
- Network monitoring: centralised logging of AP associations and periodic RF site surveys to catch unauthorized hardware early.
- User awareness: train employees to verify HTTPS/certificate warnings, avoid re-entering credentials on unexpected login prompts, and report unusual Wi-Fi behaviour immediately; enforce VPN use for accessing sensitive internal systems over Wi-Fi.

Question 4

ANSWER

Phase 1 – Wireless Reconnaissance & Compromise

- airmon-ng and airodump-ng identify the target SSID, BSSID, channel, and connected clients.
- A 4-way handshake is captured with airodump-ng (--bssid --channel -w capture) while a client (re)connects, optionally forced with aireplay-ng --deauth.
- Because the passphrase is weak, aircrack-ng (or hashcat with a wordlist) cracks the PSK offline in a short time, granting the attacker network access.

Phase 2 – Internal Network & Web Application Scanning

- Once on the network, nmap -sV -sC <subnet> discovers live hosts and identifies the internal employee-management web server and its stack.
- Gobuster/dirb enumerates hidden endpoints (e.g. /admin, /api) on the discovered web application.

- Burp Suite Spider maps the application's authentication and session-handling flow, noting any weak points (predictable session IDs, missing logout invalidation).

Phase 3 – Exploitation

- Hydra or Burp Intruder is used to brute-force weak or default login credentials against the management system's login form.
- Burp Suite is used to inspect and tamper with session cookies/tokens to test for session fixation or predictable-token issues, enabling session hijacking.
- Manual testing for Insecure Direct Object References (IDOR) — e.g. changing an employee ID in the URL/API request — to access another employee's confidential record without authorization.

Phase 4 – Privilege Escalation

- With a foothold as a low-privilege user, the attacker manipulates role/parameter values (e.g. isAdmin=true, role IDs in hidden fields or API calls) intercepted and edited via Burp Suite to attempt vertical privilege escalation.
- Lack of server-side authorization checks (only client-side/UI hiding of admin features) lets the tampered request succeed, granting administrative access to the HR/employee database.

Comprehensive Defense-in-Depth Framework

- Wireless layer: enforce WPA2/WPA3 with strong, complex passphrases or move to 802.1X enterprise authentication; segment Wi-Fi from critical internal systems using VLANs; enable 802.11w.
- Network layer: network access control (NAC), firewall rules limiting which VLANs can reach the HR application, and IDS/IPS monitoring for brute-force and scanning activity.
- Application layer: implement multi-factor authentication, strong server-side session management (random high-entropy tokens, expiry, secure cookies), and centralized server-side authorization checks (RBAC) on every request — never trust client-side role flags.
- Governance: regular penetration testing, account lockout/rate-limiting on login endpoints, security awareness training on password hygiene, and continuous logging/SIEM monitoring across both the wireless and application layers to detect the full attack chain early.

Question 5

ANSWER

How Deauthentication Attacks Are Carried Out

- The 802.11 standard defines a deauthentication management frame that a legitimate AP or client can send to end a session — but these frames are sent in the clear and were never cryptographically authenticated in the base WPA2 design.
- An attacker in radio range simply spoofs the AP's or client's MAC address and broadcasts forged deauth frames; because receivers cannot verify the sender, every targeted client immediately disconnects.
- Automated tools repeat this continuously (targeting the broadcast address or every connected client), so devices keep dropping off and reconnecting, effectively creating a denial-of-service condition.

- This exploits a fundamental protocol weakness: the lack of Management Frame Protection, not a flaw in encryption strength — even a strong WPA2 passphrase does not stop this attack.

Simulating & Analyzing in a Controlled Kali Linux Lab

- airmmon-ng start wlan0 enables monitor mode on the test adapter in an isolated/authorized lab network.
- airodump-ng wlan0mon identifies the target lab AP's BSSID and channel.
- aireplay-ng --deauth <count> -a <BSSID> wlan0mon is used to generate controlled deauth traffic against the lab AP to reproduce the disruption safely, with mdk4 as an alternative for broader flood testing.
- Wireshark captures the traffic simultaneously, filtering on wlan.fc.type_subtype == 0x0c to quantify the deauth packet rate, source MAC patterns, and correlate spikes with client disconnect events — building an evidence baseline for the campus incident.

Impact on Availability & Productivity

- Repeated disconnections during peak hours prevent students and staff from accessing online learning platforms, email, and library resources, effectively a denial-of-service on academic activity.
- Constant re-authentication attempts congest the network further, degrading performance even for unaffected users.
- Time lost to reconnecting, failed video lectures/exams, and helpdesk load translate directly into lost productivity and a poor campus experience, with possible reputational impact.

Mitigation Strategies

- Network configuration: upgrade access points to support and enforce WPA3 or, at minimum, enable 802.11w (Protected Management Frames) on the existing WPA2 infrastructure so deauth/disassociation frames must be authenticated.
- Intrusion detection: deploy a Wireless Intrusion Detection/Prevention System (WIDS/WIPS) to detect abnormal deauth frame rates in real time and alert or automatically contain the offending device.
- Segmentation & monitoring: continuously monitor RF spectrum and AP logs for anomalies, and maintain an incident-response process to physically locate a persistent attacker via signal triangulation.
- Secure protocols & policy: migrate to enterprise-grade 802.1X authentication, keep AP firmware patched, and — for mission-critical systems (exam servers, admin offices) — provide wired fallback connectivity so essential services remain available even during a wireless DoS event.